

基于生成论的网络安全分析能力调度系统

第 2 卷：对抗性安全与信息战

李龙胜

2026 年 6 月 16 日

算法可以公开，但参数必须是秘密。

借鉴密码学中 AES 的设计哲学，将安全性收敛至核心参数。

本卷建立防御方如何隐藏参数、反制探测的完整理论。

从柯克霍夫框架到 ϵ -不可区分性的严格证明，

再到探测与反探测的博弈论模型。

摘要

本卷的核心目标是：在算法完全公开的前提下，通过参数保密来构建防御方的安全边界。

2.1 节建立三层架构（公开层、秘密层、扰动层），完成 AES 设计哲学在安全运营中的迁移。

2.2 节借鉴密码学 $IND-CPA$ 范式，建立 ϵ -参数不可区分性的严格安全定义，并给出基于信息论下界、欠定推断和跨周期累积无效性的双层保障证明。2.3 节将安全分析上升为信息战，建立探测与反探测博弈模型，分析蓝队最优伪造策略与蜜罐式反探测战术。

目录

1	2.1 柯克霍夫框架：算法公开与参数保密	1
1.1	核心原则的迁移	1
1.2	三层架构	2
1.3	攻击者处境的转变	2
2	2.2 形式化安全定义：ϵ-参数不可区分性	3
2.1	从 $IND-CPA$ 到参数不可区分性	3
2.2	第一层保障：信息论下界（统计防御）	3
2.3	第二层保障：欠定推断（代数防御）	3
3	2.3 探测与反探测博弈	4
3.1	从被动采样到主动博弈	4
3.2	蓝队最优反探测策略	4
3.3	蜜罐式反探测与错觉塑造	4

1 2.1 柯克霍夫框架：算法公开与参数保密

1.1 核心原则的迁移

密码学中，一个密码系统应该做到：即便算法完全公开，只要密钥是秘密的，系统就仍然是安全的（柯克霍夫原则）。我们将这一原则迁移至安全运营领域：

算法透明化，参数密钥化。
系统的公信力建立在算法的公开审查之上，
系统的对抗安全收敛至参数的秘密性之上。

迁移对照表：

密码学	告警分级算法
加密算法（公开）	择优公式、分析率计算、配额分配算法（公开）
密钥（秘密）	核心参数： $A_i^{\min}$ 、 α_i 、扰动幅度等（秘密）
密文（可被截获）	告警流和裁定结果（攻击者可观察）
已知明文攻击	攻击者用已知攻击试探系统响应，试图反推参数

1.2 三层架构

系统被垂直划分为三个独立的层，以实现算法透明与参数保密的解耦。

定义 1.1 (公开层). 择优公式、配额分配规则、反馈更新类型（翻倍/衰减/下限保护）全部公开，接受学术界和安全社区的审查与攻击验证。

定义 1.2 (秘密层). 以下核心参数不公开，仅存储于 SOC 的加密参数库中：

- 每类告警的损失下限 $A_i^{\min}$
- 敏感度系数 α_i 的精确值
- 抗投毒衰减中使用的外部威胁情报源权重
- 翻倍系数和衰减率的确切值

攻击者即使完全了解算法，也无法精确计算裁定阈值，从而丧失了精确投毒操纵的能力。

定义 1.3 (扰动层). 在每次攻防演练或重大安全事件复盘后，对秘密参数施加微小随机扰动：

$$p_{new} = p_{old} \times (1 + \epsilon), \quad \epsilon \in [-\delta, \delta],$$

其中扰动幅度 δ 本身也是秘密。该机制等同于密码学中的密钥轮换，使攻击者的历史观测信息强制过期。

1.3 攻击者处境的转变

在柯克霍夫原则下，攻击者面对的是一个透明但不可精确预测的系统。他想要用假告警操纵 A 值，但不知道下限在哪里，制造再多假告警也无法保证压到触发忽略的阈值。

攻击者知道的	攻击者不知道的
优化公式的全部逻辑	$A_i^{\min}$ 的确切值
反馈更新的类型	衰减触发的确切阈值
每日配额分配的规则	外部威胁情报源的权重
历史告警流和裁定结果	当前周期的扰动参数

2 2.2 形式化安全定义： ϵ -参数不可区分性

2.1 从 IND-CPA 到参数不可区分性

密码学中的 IND-CPA 定义了选择明文攻击下的不可区分性。我们将此范式迁移至告警分级领域，定义“参数不可区分性”。

定义 2.1 (ϵ -参数不可区分性). 防御方维护两个秘密参数集合 θ_0 和 θ_1 。每次攻击方发起试探告警时，防御方随机选择 $b \in \{0, 1\}$ ，基于 θ_b 裁定告警并返回结果。攻击方观察结果，猜测 b 。

若对任何计算资源有限的攻击方，

$$\Pr[\text{攻击方猜对 } b] \leq \frac{1}{2} + \epsilon,$$

且 ϵ 是可通过调整参数控制的小量，则称防御方案满足 ϵ -参数不可区分性。

这个定义的价值在于：我们不要求攻击方完全猜不出参数，只要求他无法以高置信度区分两种不同的配置。这直接建立在实际的攻击方探测能力之上。

2.2 第一层保障：信息论下界（统计防御）

攻击方的核心操作是估计防御方响应概率 P_{obs} 。由 Chernoff-Hoeffding 不等式，攻击方要将估计误差控制在 Δ 以内，所需探测次数 m 的下界为：

$$m \geq \frac{1}{2\Delta^2} \ln \frac{2}{\delta},$$

其中 δ 为置信度。若防御方将 θ_0 和 θ_1 的差异 Δ 控制在 0.01，攻击方需进行约 38000 次探测。这远超其在单周期内的资源预算 (M_{max})。

跨周期累积无效性：由于参数在每个周期末被独立扰动，攻击方在不同周期收集的探测数据不具备相关性。他在新周期必须从头开始探测，之前的样本全部作废。只要 $M_{\text{period}} < m^*$ ，攻击方就永远无法完成精确推断。

2.3 第二层保障：欠定推断（代数防御）

蓝队可以主动注入噪声，以概率 q_{01} 将忽略伪装成分析，以概率 q_{10} 将分析伪装成忽略。攻击方观测到的响应概率为：

$$P_{\text{obs}}(y = 1) = r_i(1 - q_{10}) + (1 - r_i)q_{01}.$$

攻击方面对三个未知量 (r_i, q_{01}, q_{10}) ，但只有一个独立方程。这是一个欠定问题，在代数上不可能唯一确定参数值。

两层保障互补：统计上难以获得足够样本，代数上即使获得无限样本也无法求得唯一解。两者叠加，构成了 ε -参数不可区分性的完整数学基础。

3 2.3 探测与反探测博弈

3.1 从被动采样到主动博弈

传统的安全评估将攻击方的探测视为从自然中采样。但在对抗性环境中，蓝队是智能的、会主动扭曲样本的对手。探测与反探测本质上是一个非完全信息动态博弈。

定义 3.1 (探测与反探测博弈). **攻击方**：选择探测序列，目标是最大化对参数 $\mathbf{r}$ 的推断准确性。**防御方**：在每个被探测的告警类型上，选择伪造策略 (q_{01}, q_{10}) ，最大化攻击方的推断误差。蓝队受到反探测预算 C_{counter} 的约束。

3.2 蓝队最优反探测策略

蓝队的目标是使攻击方的观测样本信噪比最小化。在反探测预算有限的情况下，蓝队的资源分配遵循以下原则：

- **模糊地带强投入**：对 $r_i \approx 0.5$ 的类型，攻击方最不确定。蓝队投入少量反探测资源就能极大增加其推断难度。
- **极端伪装**：对 r_i 接近 0 或 1 的类型，蓝队只需投入极少资源制造假阳性或假阴性，就能颠覆攻击方的判断。

3.3 蜜罐式反探测与错觉塑造

攻击方会优先探测那些“历史上最少被攻击”的冷门类型。蓝队可以反向利用这一点：**蜜罐式反探测**：在攻击方可能探测的冷门方向上，故意制造少量“被分析”的伪造历史记录，让攻击方误以为这些地方重兵把守。这能将攻击方的火力引向蓝队真正布防的区域，实现了对攻击方信念的主动塑造。

4 诚实标注

命题	状态	层级
----	----	----

柯克霍夫三层架构	框架完整，逻辑自治，与 AES 设计哲学同构	II（跨领域适用性待验证）
参数不可区分性定义	形式化定义已建立，术语已明晰	II（安全参数的量化待社区共识）
信息论下界（Chernoff-Hoeffding）	基于标准的概率不等式，推导严格	I（不依赖未证明假设）
欠定推断的不可能性	方程组系数矩阵的秩分析，结论严格	I（严格数学结论）
最优反探测策略	定性结论已给出，符合直觉和博弈论原理	II（精确解待实验数据标定）
蜜罐式反探测	概念已形式化，战术启发性强	III（实战效果待红蓝对抗检验）

文档信息：

- 作者：李龙胜
- 版本：v1.0（四卷体系重构第 2 卷）
- 许可：CC BY 4.0
- 前置依赖：第 0 卷、第 1 卷